

Lesson 5

Penetration Testing 3 – Privilege Escalation

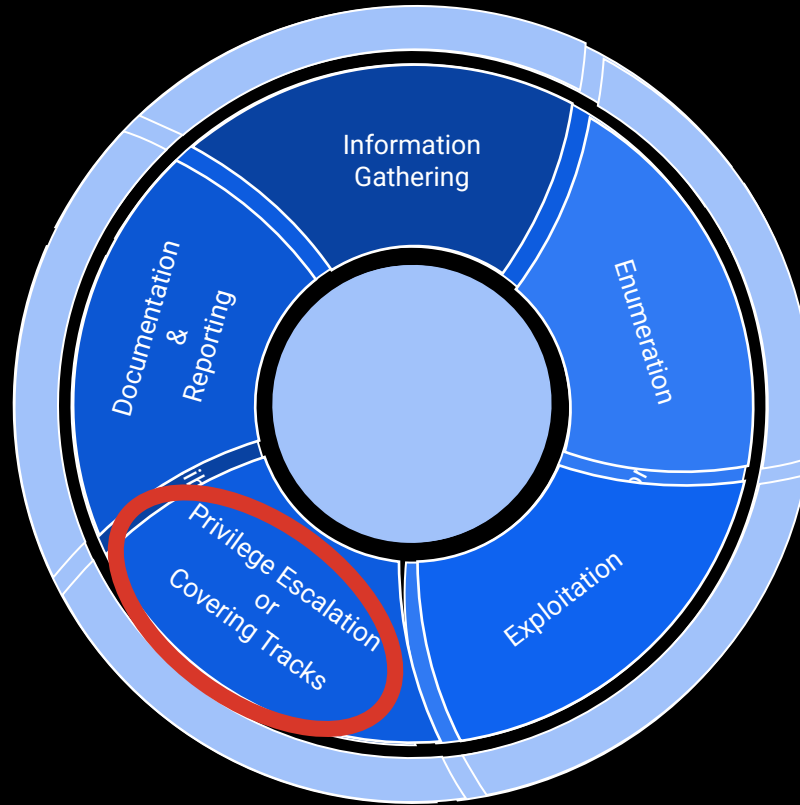
Disclaimer

What you will go through in this course, is highly highly niched skills that can make you a highly valuable asset in an organization, or an overnight criminal when things are done without permission, or the right ethical considerations.

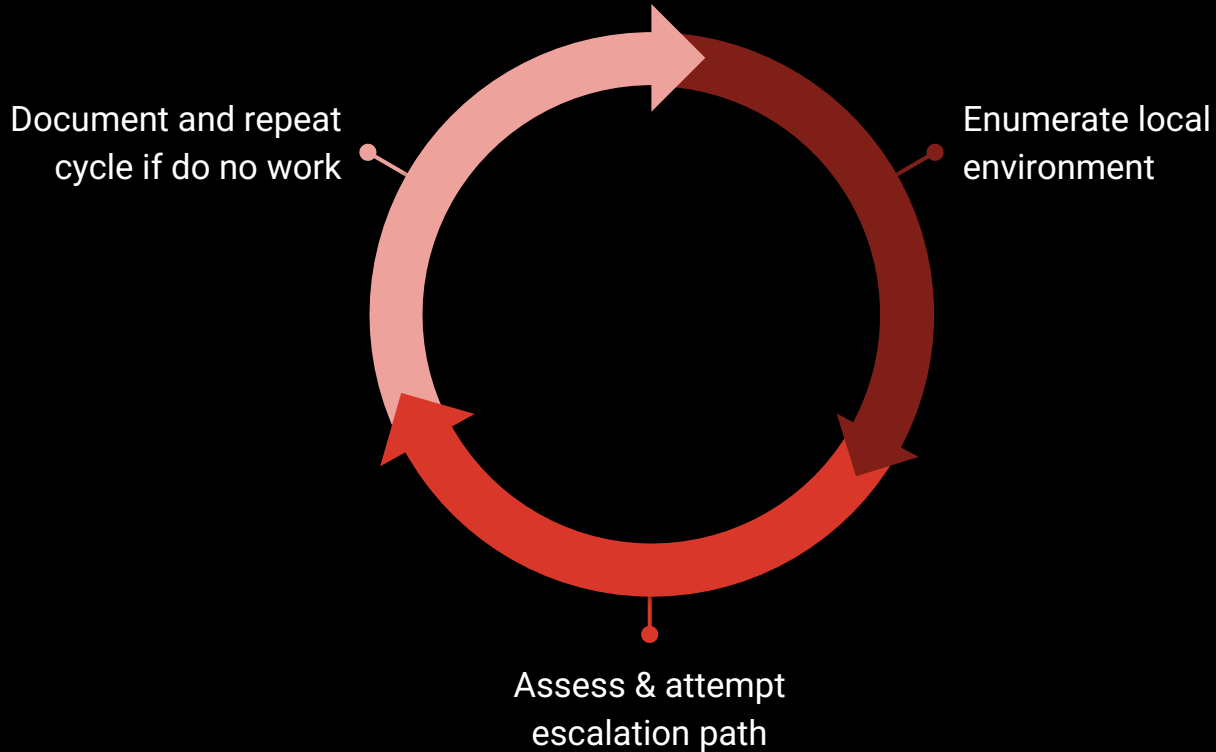
You CAN land in trouble if you breach the computer misuse act, and in no capacity I will be vouching for you, sanctioning you, or even allowing you to attack on properties that are not own by me, or for lesson purpose.

So please, help me to help you by not doing anything taught in class, onto someone else.

Penetration Testing Life Cycle



The Privilege Escalation Cycle



Privilege Escalation

In Privilege Escalation, we are focused on moving from one “less privileged” principle to one “more privileged” or admin principle.

That means, moving Laterally or Vertically in a privilege domain.

Types of Privilege Escalation

Web Application Privilege Escalation

- Role Based Privilege Escalation
- Web to System Escalation

System Privilege Escalation

- Linux
- Windows

Web Application Privilege Escalation

Role Based Privilege Escalation

- Target authentication logic
- Misconfigured web resource

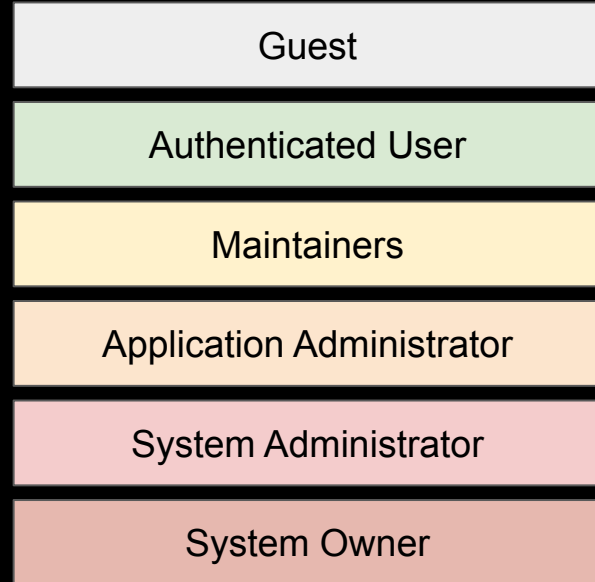
Web to System Escalation

- Remote Code Execution
- Object Deserialization
- Executing System Functions Without Sandbox

Web Application Privilege Escalation

Understanding privilege levels.

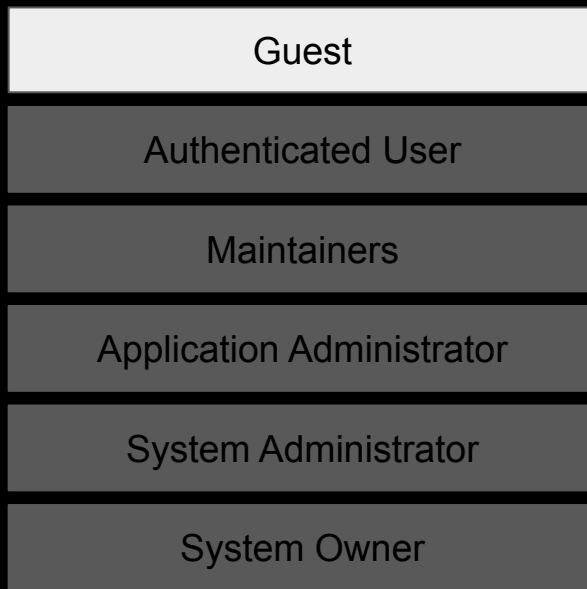
Each levels have its own set of permission sets and use cases.



Web Application Privilege Escalation

Guest users are also known as Unauthenticated Users.

These users are your typical site visitors, users without accounts, and should have no access to any non-public data or function that requires authentication/identity.



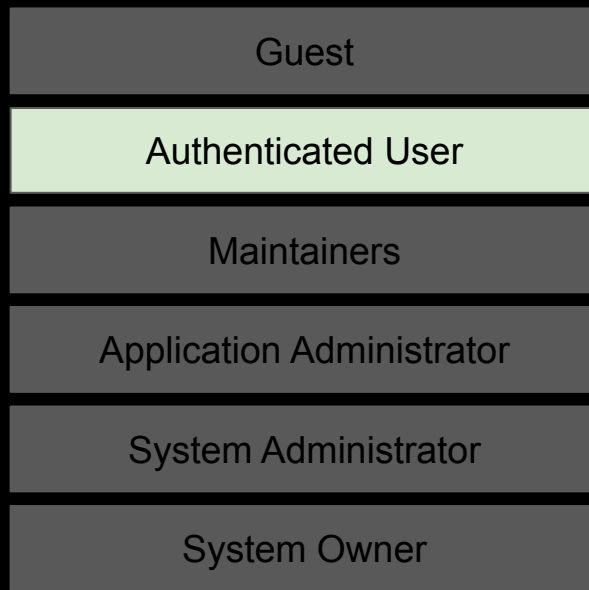
Web Application Privilege Escalation

Next, you have authenticated users. These users are sometimes “not guest” but can be considered “guest”.

Example: Workday users, Github users

Also... Are Twitter user “guest” users?

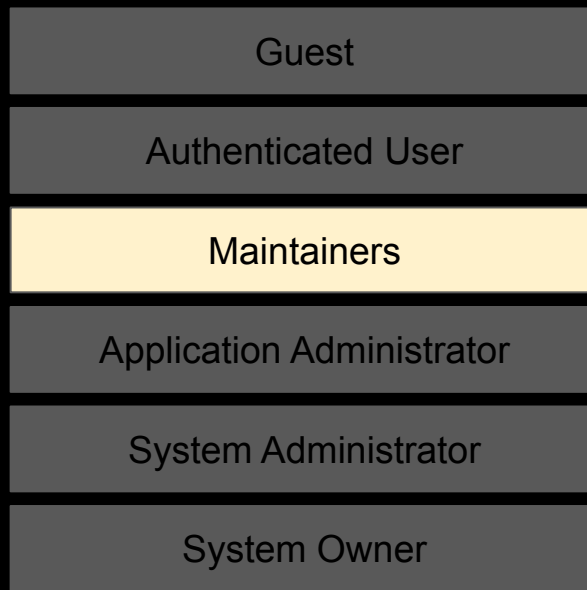
Consider the “data access model”



Web Application Privilege Escalation

These users are usually either community or hired members that maintain an application, such as blog writers, widget maintainers, or project contributors.

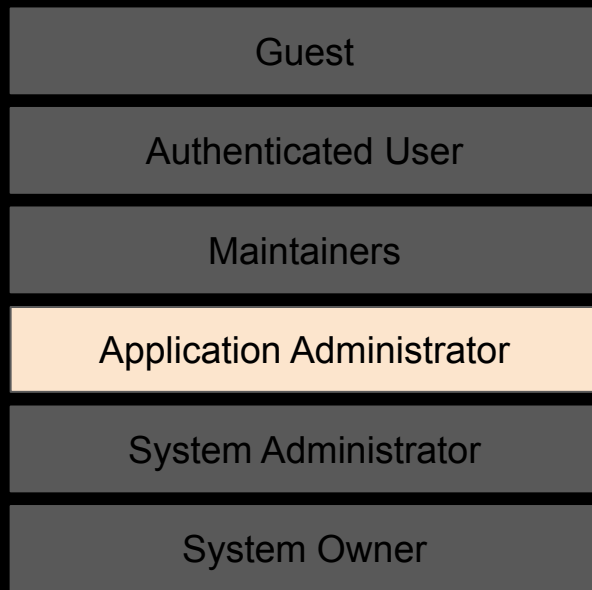
They have some level of privilege access, and can be seen as high value targets in certain scenarios.



Web Application Privilege Escalation

Application administrators are users who do not have access over the system, but have full control over the application.

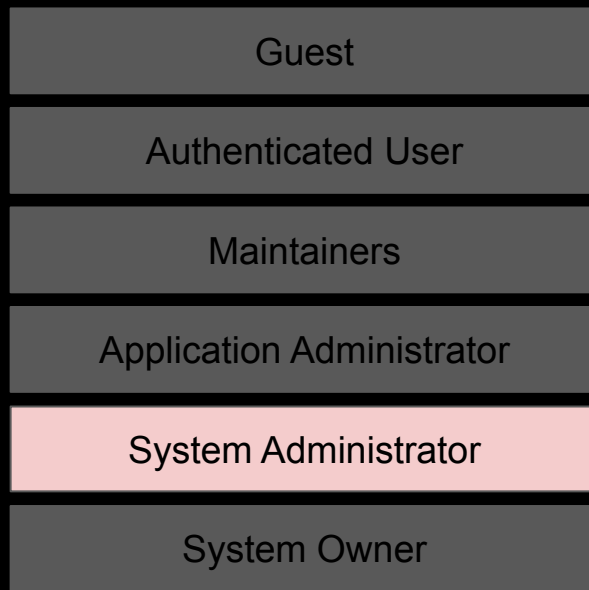
This include assigning users roles, create update delete users, adding new plugins that can result to an application change, or administer entire project/web application with no restriction



Web Application Privilege Escalation

These users are usually administrators of systems that hosts applications. They do not have the knowledge of application architecture, but the knowledge of system architecture and network architecture.

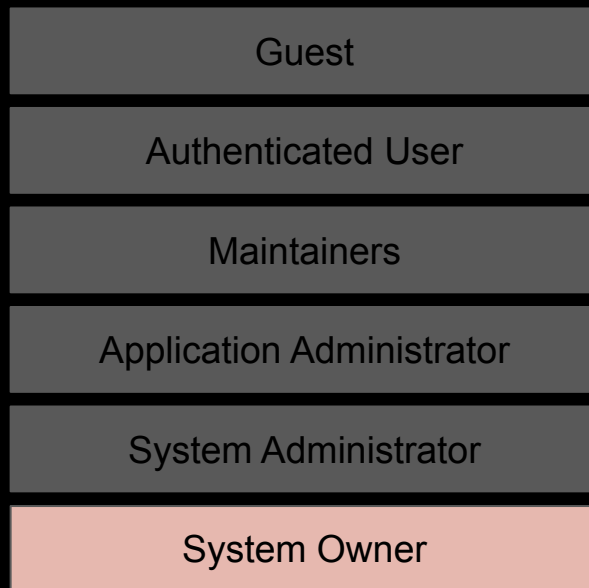
These users usually have overwriting powers over Application Administrator due to the fact that they have access over application artifacts and yields higher access.



Web Application Privilege Escalation

These users have full control over the system, and underlying technologies that supports the web application.

Moving towards here is as good as getting cooked. (it means it is over for the system owner if the hacker gets here)



Web Application Privilege Escalation

Role Based Privilege Escalation

- Target authentication logic
 - Cookie tampering
 - Changing browser cookie values such as changing from “user” to “admin” in role section of a cookie
 - Session tampering
 - Session tampering by adding or removing certain session/cookie values that can allow impersonation or coercing of server to grant permissions
- Misconfigured web resource
 - Admin panel access without authentication (accessing /admin of a web portal)
 - Misconfigured user access control
 - IDOR on web role feature (when updating user profile, you can update user role as well as a user)

Examples

Change cookie value for UID to something else

Or change Role to “admin”

The screenshot shows the Chrome DevTools 'Resources' tab with the 'Cookies' section expanded for the domain 'lab.local'. The 'PHPSESSID' cookie is selected, and its 'Value' column is expanded to show 'UID' with value '1' and 'Role' with value 'admin'. A red circle with a checkmark is around the 'HTTP' column header.

Name	Value	Domain	Path	Expires / Max-Age	Size	HTTP	Secure
Cookie	Normal	lab.local	/	Session	12		
PHPSESSID	tgce245t7alseaugc36nvbu681	lab.local	/	Session	35	✓	
UID	1						
Role	admin						

Examples

Change cookie value for UID to something else

Or change Role to “admin”

Prevent this with Signed/Encrypted Cookie

Name	Value	Domain	Path	Expires / Max-Age	Size	HTTP	Secure
Cookie	Normal	lab.local	/	Session	12		
PHPSESSID	tgce245t7alseaugc36nvbu681	lab.local	/	Session	35		☒

Web Application Privilege Escalation

Web to System Escalation

- Remote Code Execution
 - Execute code based on code injection
 - PHP system() injection
 - Python eval() injection
- Object Deserialization
 - Object deserialization
 - PHP, Java, Python... (any form of serialize and deserialize)
- Executing System Functions Without Sandbox
 - Example:
 - Ping IP address without doing it in a sandbox
 - Execute user supplied system command in a non sandbox environment

https://owasp.org/www-community/vulnerabilities/PHP_Object_Injection

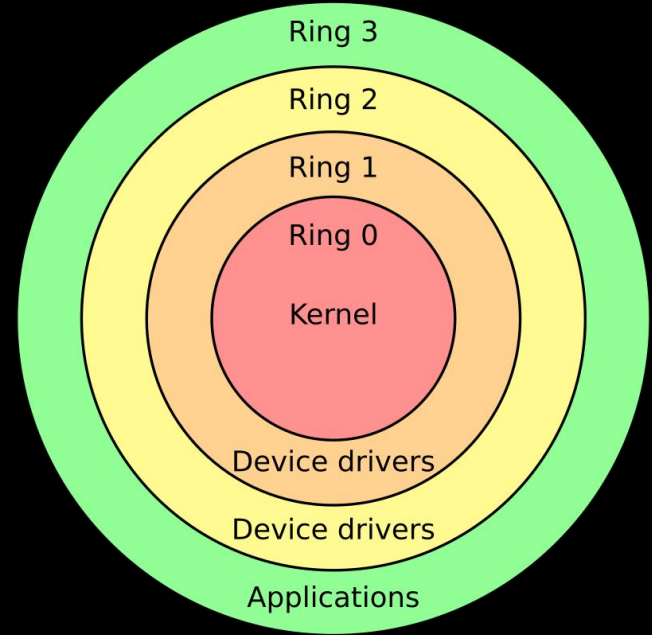
<https://portswigger.net/web-security/os-command-injection#what-is-os-command-injection>

So what?

Now you are at USER LAND.

This means, you traversed from Web (or service based) to local user privilege.

Your permissions are usually a normal/lower privileged user. Unless the service you exploited is executed by a high privileged or root/administrator user, your access is usually a normal user.



System Privilege Escalation

System Privilege Escalation

- Linux
- Windows
- MacOS (we will briefly cover only)

Linux System Privilege Escalation

We dub the Linux System Privilege Escalation into three main categories:

- Kernel/Driver exploit
- Misconfigured services
- root SUID/GUID exploitation

Linux System Privilege Escalation

Kernel/Driver exploit

Often part first “low hanging fruit” to clear

Use the command “uname -a” to identify Kernel version

Exploit are published in the wild

Some Noteable Kernel Exploits: Dirtyc0w, DirtyPipe

Usually discovered by Zero Day researcher

Exploitation of local services that can result to root

Linux System Privilege Escalation

Misconfigured services

Often mistakes are made through configuration

Some common misconfiguration includes:

- sudo command being executed by anyone
- Cron Job runs on data retrieved from a world writable file
- System Service running based on data retrieved from a world writable file
- Exploit services that are executed with high privileges through misconfigured file access

Linux System Privilege Escalation

root SUID/GUID exploitation

Often a setuid bit is set to this binary.

Setuid (Set User ID) is a special permission bit in Unix-like systems that allows a program to run with the privileges of its owner, rather than the user executing it. This enables a user to perform tasks requiring higher privileges, such as changing a password with the `passwd` command, without permanently granting them root access. 

Linux System Privilege Escalation

root SUID/GUID exploitation

So if a binary belongs to root, or a higher privilege user, you can run as that user in your current permission set. What if that binary allows command execution?

Example:

vim/vi text editor allows command execution with “!shell” command in the editor.

This is call “living of the land”, and you can refer to GTFO bins.

<https://gtfobins.github.io/>

Linux System Privilege Escalation

The end goal of privilege escalation is always to move from one permission set to next. Never must it always result to root, but it can be the end goal.

Enumerate Enumerate Enumerate

You can run LinPEAS to automate some of the priv-esc scanning!

<https://github.com/peass-ng/PEASS-ng/tree/master/linPEAS>

Windows System Privilege Escalation

We dub the Windows System Privilege Escalation into two main categories:

- Kernel/Driver exploit
- Misconfigured services

Any other methods are out of scope for this curriculum.

In Windows, there are two “super users”. Mainly Administrator and SYSTEM.

SYSTEM has more permissions and power over Administrator

Windows System Privilege Escalation

Kernel/Driver exploit

Also often part first “low hanging fruit” to clear

Use the command “systeminfo” to identify OS version

Exploit are published in the wild

Usually discovered by Zero Day researcher

Exploitation of local services that can result to Administrator/SYSTEM

Windows System Privilege Escalation

Misconfigured services

Also, often mistakes are made through configuration

Some common misconfiguration includes:

- Scheduled Task runs on data retrieved from a world writable file
- System Service running based on data retrieved from a world writable file
- Exploit services that are executed with high privileges through misconfigured file access
- Access to services which results to high privilege with injection attacks

Windows System Privilege Escalation

The end goal of privilege escalation is always to move from one permission set to next. Never must it always result to Administrator, but it can be the end goal.

Enumerate Enumerate Enumerate

You can run WinPEAS to automate some of the priv-esc scanning!

<https://github.com/peass-ng/PEASS-ng/tree/master/winPEAS>

Windows System Privilege Escalation

Instead of targeting Administrator/System, you might want to target users in other security groups as well within the same windows environment. But this depends on your Rules of Engagement

So... why....

Whenever you hit a new “Land”, we first have to enumerate.

Understand what commands we can or cannot run.

So, we have to explore. Here are some readings (**compulsory** reading):

<https://github.com/nickvourd/Windows-Local-Privilege-Escalation-Cookbook>

https://sushant747.gitbooks.io/total-oscp-guide/content/privilege_escalation_windows.html

https://sushant747.gitbooks.io/total-oscp-guide/content/privilege_escalation_-_linux.html

<https://delinea.com/blog/linux-privilege-escalation>

Break Time

Hands On Exercise

Let's Hack HYDROGEN

Login as student:password

Now try to priv-escalate to root on your own. :)

There are 5 flags in total.